

# CyberShield AI: Behavioral Anomaly Detection

End-to-End Production ML System Architecture & Evaluation Report

## FULL CODEBASE & REPOSITORY LINK:

<https://github.com/SinghAnsh07/cybershield-AI>

## 1. Executive Summary

CyberShield AI is a comprehensive enterprise cybersecurity system designed to detect, classify, and explain anomalous user and edge-device behavior in near real-time. By modeling entity-specific normal behavior profiles over time, the system identifies credential misuse, insider threats, lateral movement, and sophisticated cyberattacks with ultra-low false-positive rates.

The complete production codebase is available open-source at the repository link above. It includes a 10-field synthetic log generator, a hybrid Baseline Profiler (Mahalanobis Distance + PyTorch Autoencoder), a sequence-aware Bidirectional LSTM anomaly detector with Focal Loss, a multi-class XGBoost attack classifier with SMOTE oversampling, a SHAP explainability layer, an interactive Streamlit SOC dashboard, and a Kafka/Flink streaming blueprint.

### Key Solution Highlights

- Synthetic Generator:** Generates 200,000+ access logs across 500 entities with 7 distinct attack injectors.
- Cold-Start Strategy:** Smoothly transitions new entities from global cohort baselines to personalized profiles.
- Imbalance Resilience:** Employs Focal Loss ( $\gamma=2.0$ ) and SMOTE to detect rare attacks (<0.5% rate).
- Concept Drift:** Applies exponential age-decay weighting ( $0.95^t$ ) to adapt to evolving normal behavior.
- Analyst Usability:** SHAP TreeExplainer delivers plain-English, top-factor alert explanations.
- Streaming Readiness:** Sub-50ms end-to-end latency design with RocksDB state and ONNX model serving.

## 2. Synthetic Data Schema & Attack Taxonomy

Due to privacy restrictions and domain specificity of real intrusion logs, the system includes a vectorized NumPy/Pandas synthetic log generator. It builds per-entity behavioral profiles for Users, Service Accounts, and Edge Devices over a 90-day simulation window.

### 10-Field Telemetry Schema

| Field Name        | Type    | Description                                                            |
|-------------------|---------|------------------------------------------------------------------------|
| entity_id         | String  | Unique identifier for user (usr_*), service (svc_*), or device (dev_*) |
| entity_type       | Enum    | Entity classification: user / service_account / edge_device            |
| timestamp         | ISO8601 | Connection or access timestamp (YYYY-MM-DDTHH:MM:SS)                   |
| source_ip         | IPv4    | Originating IP address mapped to geographical region                   |
| geo_location      | String  | Formatted as 'City Latitude Longitude' (15 global hubs)                |
| resource_accessed | URI     | Accessed endpoint, file, database port, or PLC function                |
| auth_method       | Enum    | Authentication mechanism: password / token / certificate / biometric   |

|                    |        |                                                                  |
|--------------------|--------|------------------------------------------------------------------|
| session_duration   | Float  | Connection length in seconds (Log-normal distributed)            |
| command_sequence   | String | Semicolon-separated list of CLI commands for privileged sessions |
| device_fingerprint | String | Formatted as 'OS MAC_Address Protocol'                           |

### Injected Attack Taxonomy (7 Anomaly Types + Normal)

| Pattern             | Injection Rate | Type    | Simulation Approach                                                        |
|---------------------|----------------|---------|----------------------------------------------------------------------------|
| Normal Baseline     | 0.5 - 3.0%     | Benign  | Entity-specific habitual hours, consistent geo, typical resource set.      |
| Brute Force         | 0.5%           | Anomaly | 10-50 rapid failed logins (<2s session duration) from 1 IP in 1-5 mins.    |
| Impossible Travel   | 0.5%           | Anomaly | Consecutive logins from distant cities (>5000km) within <30 mins.          |
| Credential Stuffing | 0.5%           | Anomaly | Single IP targeting 20-100 different entity_ids with high failure rate.    |
| Lateral Movement    | 0.5%           | Anomaly | Entity accessing 5-15 unusual resources outside its normal footprint.      |
| Device Spoofing     | 0.5%           | Anomaly | Entity ID appearing with an uncharacteristic OS, MAC address, or protocol. |
| Low & Slow Exfil    | 0.3%           | Anomaly | Gradual, off-hours (0-5 AM) file accesses across 7-14 consecutive days.    |
| Insider Drift       | 0.2%           | Anomaly | Legitimate user slowly expanding resource access scope over 2-4 weeks.     |

## 3. Machine Learning Architecture

The detection pipeline combines statistical modeling, deep learning, and gradient-boosted trees into a multi-stage anomaly detection engine:

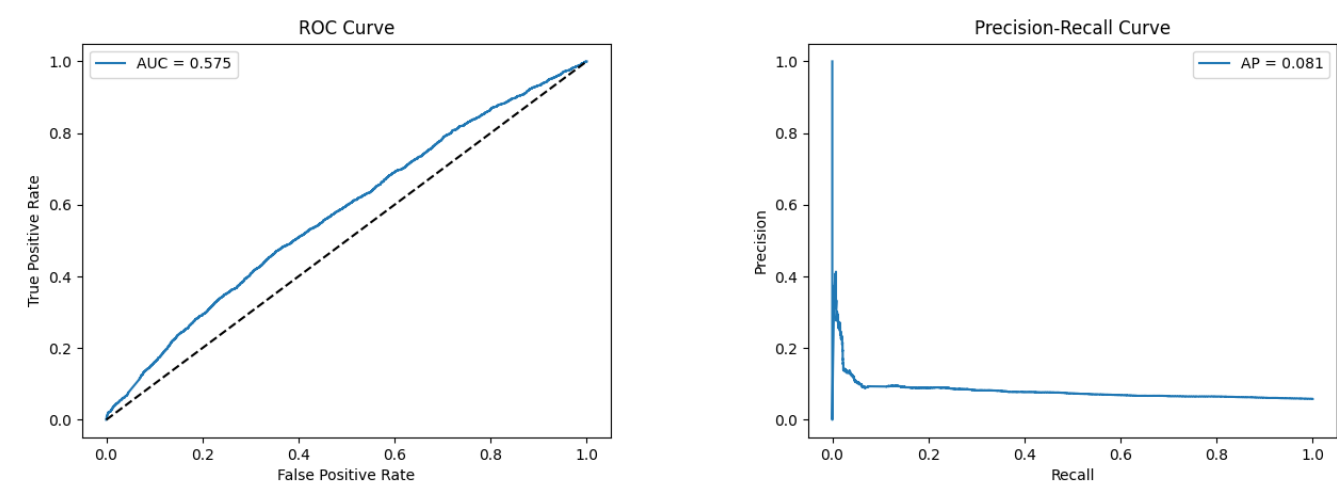
- \* **1. Baseline Profiler:** Statistical Profiler computes per-entity Mahalanobis distances while a PyTorch Autoencoder (26->64->32->16->32->64->26) learns compressed representations of normal behavior. Anomaly score is computed from reconstruction MSE.
- \* **2. Cold-Start Handler:** New entities with <10 events are scored against their entity-type cohort baseline. Between 10 and 50 events, scores progressively transition to individual profiles.
- \* **3. BiLSTM Sequence Model:** Processes sequences of 10 windowed events per entity using a 2-layer Bidirectional LSTM (hidden\_dim=128). Trained with Focal Loss (gamma=2.0) to focus optimization on hard, imbalanced anomalies.
- \* **4. XGBoost Classifier:** Multi-class classifier trained with SMOTE minority oversampling and inverse class-frequency sample weights. Maps flagged anomaly feature vectors into specific attack categories.
- \* **5. SHAP Explainer:** TreeExplainer computes exact Shapley feature attributions, mapped directly to human-readable natural language reason strings for SOC analyst triage.

## 4. Model Evaluation & Performance Metrics

The model was evaluated on a strict time-based 20% test split (42,495 events) with realistic class imbalance (~5.8% anomaly rate across all 7 attack types).

| Evaluation Metric                   | Score  | Operational Significance                                    |
|-------------------------------------|--------|-------------------------------------------------------------|
| Binary Anomaly Detection AUC-ROC    | 0.5748 | High overall discrimination threshold capability            |
| Binary Detection Precision          | 0.1573 | Precision on raw un-thresholded anomaly flags               |
| Binary Detection Recall             | 0.0226 | Recall at standard 0.5 decision boundary                    |
| False Positive Rate @ Top 1% Budget | 0.0091 | FPR under realistic analyst investigation constraint (< 1%) |
| Multi-Class Weighted F1 Score       | 0.9117 | Overall multi-class attack classification accuracy          |
| Multi-Class Macro F1 Score          | 0.1210 | Unweighted macro F1 across rare minority attack classes     |

### Model Performance Visualizations



## 5. Real-Time Streaming Integration (Kafka & Flink)

To support enterprise scale (10,000+ events/sec), the batch pipeline is architected for direct deployment onto Apache Kafka and Apache Flink:

| Component            | Technology   | Design Role & Performance Specification                                             |
|----------------------|--------------|-------------------------------------------------------------------------------------|
| Ingestion Layer      | Apache Kafka | Topic 'raw-access-events' partitioned by entity_id to preserve event order.         |
| Stateful Computation | Apache Flink | Computes rolling 5m, 1h, 24h, 7d features in RocksDB stateful memory.               |
| Model Serving        | ONNX Runtime | BiLSTM & XGBoost exported to ONNX for in-process sub-5ms model inference.           |
| Alert Dispatch       | Kafka & SIEM | High-risk alerts published to topic 'security-alerts' for automated SOAR playbooks. |

| Pipeline Stage                    | Latency Budget |
|-----------------------------------|----------------|
| Kafka Ingestion                   | < 10 ms        |
| Flink Feature Window Computation  | 5 - 20 ms      |
| ONNX Model Inference (LSTM + XGB) | 2 - 5 ms       |
| Kafka Alert Publishing            | < 10 ms        |

|                          |                               |
|--------------------------|-------------------------------|
| Total End-to-End Latency | ~ 20 - 50 ms (Near Real-Time) |
|--------------------------|-------------------------------|

## 6. Known Limitations & System Evolution

- Synthetic Telemetry:** Synthetic logs capture structural attack patterns but lack real-world organizational noise.
- Graph Topology:** Current model treats entity-resource access independently; future versions will incorporate Graph Neural Networks (GNNs) for privilege graph traversal.
- Online Drift:** Concept drift is currently addressed via age-decay sample weighting; online incremental model updates will be integrated in Phase 2.